App security checks: protected data, recovery and production exposure

Researched 2026-11-07.

Strengths and best use

The ten checks prioritize realistic failure paths in a small web application. Protected data, privileged keys, request abuse, uploads, password resets, and dependency exposure are concrete places to gather evidence. Supabase documents the distinction between publishable keys and privileged secrets, and how RLS constrains exposed data. API keys (https://supabase.com/docs/guides/api/api-keys) - RLS (https://supabase.com/docs/guides/database/postgres/row-level-security)

Verify access with fixtures

Create two synthetic users, a restricted role, and an unauthenticated caller. Exercise each protected read, write, export, storage, and bulk route using objects owned by different users. Check effective grants and RLS policies. Test server-side authorization even where a browser hides the control. For AI endpoints, measure request and spending limits and their failure behavior.

Check recovery and delivery

Validate uploads using server-side content checks, size limits, storage permissions, and safe serving behavior. Verify reset token expiry, single use, and account-disclosure behavior against the actual threat model. Review dependency advisories for reachable production exposure and evaluate fixes before applying them. Connect useful logs to a monitored alert and recovery procedure. Uploads (https://cheatsheetseries.owasp.org/cheatsheets/File_Upload_Cheat_Sheet.html) - Reset guidance (https://cheatsheetseries.owasp.org/cheatsheets/Forgot_Password_Cheat_Sheet.html) - npm audit (https://docs.npmjs.com/cli/v11/commands/npm-audit/)

```
npm audit --omit=dev
```

Reusable prompt

```
Select applicable controls for this application using synthetic accounts and owned fixtures. For each test record expected behavior, observation, evidence, fix, and retest. Include cross-user access, privileged keys, AI spending limits, uploads, reset links, and dependency reachability. Prioritize failures by impact.
```

Project idea

Extend a launch evidence workbook with an access matrix and repeatable negative tests. Use ASVS to expand coverage for the application's actual risk. ASVS (https://owasp.org/www-project-application-security-verification-standard/)

Original sources

- https://www.instagram.com/reel/DfXVSPWBkDu/